



UNIVERSIDAD TECNOLÓGICA DE CHETUMAL

Docente: ING. Allan Alonso Cordova Lechuga

Grupo: IDGSAV25 **Turno:** Vespertino

Cuatrimestre: 8

Alumna: Andrea Alexia Dionicio Tah

Carrera: ING. Desarrollo de Software Multiplataforma

Parcial: 2



BITÁCORA DE AUDITORÍA

DATOS GENERALES

Empresa: JobBy **Nombre del líder auditor:** Diego Beltran Can

Nombre del responsable: Andrea Alexia Dionicio Tah

Función del responsable: Administración de base de datos

Fecha de inicio: 02/03/2025

Fecha de fin: 10/03/2026

REGISTRO DE ACTIVIDADES

Fecha y hora	Actividad realizada	Evidencias	Hallazgos
_02/_03/_202 6__18_:44_	Al comenzar la primera auditoria un escaneo para saber si contiene una web a la ip ya encntrada por elequipo.	Whatweb 10.252.1.134	Se encontro que el servidor usado es ubuntu linux y que si se encuenra una web
_02/_03/_202 6__18_:34_	De igual forma se hizo un escaneo de	Nmap -sX 10.252.2.104	Se encontraron los servicios ssh, http, mysql pero en esatado firiltrado, lo que podria

	puertos y servicios		significar estar protegidos por un firewall.
_02/_03/_202 6__18__:51__	Como tercer paso, un escaneo a ese Puerto (80).	Nmap -sVC -p80 10.0252.2.104	Se identificó un servidor web mini_httpd con un rendimiento automático en el puerto 8080, como un proxy.
_02/_03/_202 6__18__:51__	Escaneo de host para encontrar la ip correcta	Nmap -sn 10.252.0.0/22	Se permitió mapear toda la infraestructura de la red.
_03/_03/_202 6__17__:33__	Como primer paso, a la ip encontrada por el equipo se le lanza un escaneo para saber si cuenta con una web.	Whatweb 10.252.0.91	Se detectó un servidor Apache 2.4.58 sobre Ubuntu.
_03/_03/_202 6__18__:00__	Al saber que existe una web, se accede a ella por el navegador.	http://10.252.0.91	Se visualizó un proyecto Laravel. Con archivos sensibles como composer.json y la carpeta database/.

_03/_03/_2026__18_:01_	Analizando las rutas, se descubrió que la ip le correspondia a "Medicura".	Navegación http://database/migrations/	Se identificaron los scripts de creación de 4 tablas/estructuras de bases de datos: users, cache, jobs y personal_access_tokens. Esto revela la lógica de almacenamiento de Medicura.
_03/_03/_2026__18_:10_	Por ultimo, se escaneo otra ip.	Gobuster dir -u http://10.252.1.187	Se analizó otra ip, pero al final por tiempo no se encontró.
09/_03/_2026__17_:04_	Al principio del día 3, se escaneo la ip de vulnerabilidades para identificar riesgos en el servidor.	Nikto -h 10.252.3.45	Se detectó falta de cabeceras de seguridad (X-Frame-Options, X-Content-Type). O sea que la BD podría presentar riesgos.
09/_03/_2026__18_:33_	En la clase pasada, se encontró que la BD usada para	Por ello se uso: nmap -p 27017 10.252.3.45	El puerto 27017 (MongoDB) aparece como filtered. Indica

	“SOJAI” era Mongo DB		que hay un firewall protegiendolo.
09/_03/_2026 __18_:52__	Finalmente, se intent un ataque de fuerza para localizer archivos.	dirb http://10.252.3.45	Se localizaron rutas críticas: /login, /storage y /up. Osea que se podrían hacer ataques de subida de archivos maliciosos.

OBSERVACIONES GENERALES

___Día 1: Durante el día uno, se detectó no se encontro mucho, por lo que solo se hizo un escaneo en busqueda de la ip de objetivo. ___

___Día 2: En esta Segunda clase, se logró el acceso a la lectura de archivos de migración del backend del proyecto Medicura. Obteniendo el esquema exacto de la tabla de usuarios. Esto puede permitir identificar contraseñas. _____

___Día 3: Aunque el puerto 27017 está filtrado, la aplicación web se vio vulnerable a ataques de Inyección NoSQL a través de los formularios de /login _____

Evidencias

Anexo 1.

```
(kali@andreakali) ~
$ whatweb 10.252.1.134
ERROR: Opening: https://10.252.1.134 - Connection refused - connect(2) for "10.252.1.134" port 443
http://10.252.1.134 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], IP[10.252.1.134], Title[Apache2 Ubuntu Default Page: It works]
```

Anexo 2



```
(kali@andreakali)-[~]
$ nmap -sX 10.252.2.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-02 18:33 EST
Nmap scan report for 10.252.2.104
Host is up (0.032s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE      SERVICE
80/tcp    open|filtered http
443/tcp   open|filtered https
4343/tcp  open|filtered unicall
8080/tcp  open|filtered http-proxy
MAC Address: 48:B4:C3:CB:E8:8C (Aruba, a Hewlett Packard Enterprise Company)

Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds
```

Anexo 3

```
(kali@andreakali)-[~]
$ nmap -sVC -p80 10.252.2.104
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-02 18:34 EST
Nmap scan report for 10.252.2.104
Host is up (0.0077s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      mini_httpd
|_http-title: Did not follow redirect to http://10.252.2.104:8080/
|_http-server-header: <empty>
MAC Address: 48:B4:C3:CB:E8:8C (Aruba, a Hewlett Packard Enterprise Company)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.33 seconds

(kali@andreakali)-[~]
```

Anexo 4

```
(kali@andreakali)-[~]
$ nmap -sn 10.252.0.0/22
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-02 17:58 EST
Nmap scan report for 10.252.0.1
Host is up (0.0092s latency).
MAC Address: E8:1C:BA:FE:FB:CA (Fortinet)
Nmap scan report for 10.252.0.11
Host is up (0.0070s latency).
MAC Address: CC:2D:21:2C:E4:10 (Tenda Technology,Ltd.Dongguan branch)
Nmap scan report for 10.252.0.12
Host is up (0.12s latency).
MAC Address: D2:98:5F:4B:57:65 (Unknown)
Nmap scan report for 10.252.0.19
Host is up (0.076s latency).
MAC Address: B2:F2:3F:D9:72:74 (Unknown)
Nmap scan report for 10.252.0.21
Host is up (0.020s latency).
MAC Address: B4:FB:E4:27:AF:54 (Ubiquiti)
Nmap scan report for 10.252.0.33
Host is up (0.25s latency).
MAC Address: C2:16:ED:9B:B9:0D (Unknown)
Nmap scan report for 10.252.0.36
Host is up (0.012s latency).
MAC Address: 4C:D9:8F:7F:52:A4 (Dell)
Nmap scan report for 10.252.0.40
Host is up (0.31s latency).
MAC Address: 9E:38:C1:AE:7F:CE (Unknown)
Nmap scan report for 10.252.0.64
Host is up (0.13s latency).
MAC Address: 1A:E3:0D:A9:C4:68 (Unknown)
Nmap scan report for 10.252.0.71
```

Anexo 5

```
(kali@andreakali)-[~]
$ whatweb 10.252.0.91
ERROR Opening: https://10.252.0.91 - SSL_connect returned=1 errno=
0 peeraddr=10.252.0.91:443 state=error: record layer failure
http://10.252.0.91 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ],
HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], IP[10.252.0.91]
, Index-Of, Title[Index of /]
```

Anexo 6

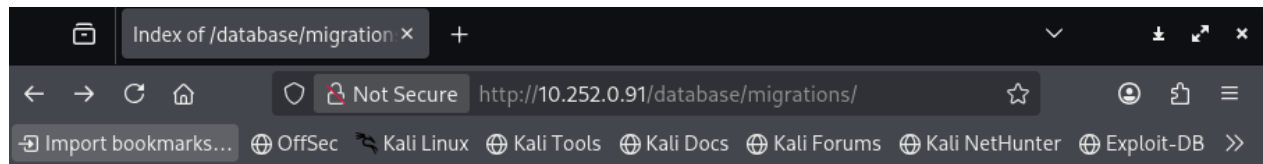
Index of /

Not Secure http://10.252.0.91

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali N

Index of /

Name	Last modified	Size	Description
 README.md	2025-04-02 23:55	4.0K	
 app/	2026-03-03 00:28	-	
 artisan	2025-04-02 23:55	350	
 bootstrap/	2026-03-03 00:28	-	
 composer.json	2025-04-02 23:55	2.4K	
 composer.lock	2025-04-02 23:55	317K	
 config/	2026-03-03 00:28	-	
 database/	2026-03-03 00:28	-	
 medicura/	2026-03-03 00:43	-	
 node_modules/	2026-03-03 00:32	-	
 package-lock.json	2025-04-02 23:55	122K	
 package.json	2025-04-02 23:55	383	
 phpunit.xml	2025-04-02 23:55	1.2K	
 postcss.config.js	2025-04-02 23:55	93	



Index of /database/migrations

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory		-	
0001_01_01_000000_create_users_table.php	2025-04-02 23:55	1.4K	
0001_01_01_000001_create_cache_table.php	2025-04-02 23:55	849	
0001_01_01_000002_create_jobs_table.php	2025-04-02 23:55	1.8K	
2025_03_21_154353_create_personal_access_tokens_table.php	2025-04-02 23:55	856	

Apache/2.4.58 (Ubuntu) Server at 10.252.0.91 Port 80

Anexo 8

```
(kali@andreakali)-[~]
$ gobuster dir -u http://10.252.1.187 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 50 -x php,html,txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.252.1.187
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)
2026/03/03 19:41:24 error on running gobuster on http://10.252.1.187/: unable to connect to http://10.252.1.187/: Get "http://10.252.1.187/": unsupported protocol scheme ""

(kali@andreakali)-[~]
```

Anexo 9:

```
$ nikto -h 10.252.3.45
- Nikto v2.5.0

+ Target IP: 10.252.3.45
+ Target Hostname: 10.252.3.45
+ Target Port: 80
+ Start Time: 2026-03-09 16:51:34 (GMT-6)

+ Server: Apache/2.4.66 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See:
ons
+ /: The X-Content-Type-Options header is not set. This could allow the
o the MIME type. See: https://www.netsparker.com/web-vulnerability-scan
+ /: Cookie XSRF-TOKEN created without the httponly flag. See: https://
```

Anexo 10:

```

$ dirb http://10.252.3.45 /usr/share/wordlists/dirb/common.txt

DIRB v2.22
By The Dark Raver

START_TIME: Mon Mar 9 17:04:44 2026
URL_BASE: http://10.252.3.45/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

GENERATED WORDS: 6012

--- Scanning URL: http://10.252.3.45/ ---
+ http://10.252.3.45/cgi-bin/ (CODE:301|SIZE:351)
+> DIRECTORY: http://10.252.3.45/css/
+ http://10.252.3.45/favicon.ico (CODE:200|SIZE:0)
+> DIRECTORY: http://10.252.3.45/images/
+ http://10.252.3.45/index.php (CODE:200|SIZE:10337)
+> DIRECTORY: http://10.252.3.45/js/
+ http://10.252.3.45/login (CODE:200|SIZE:10340)
+ http://10.252.3.45/logout (CODE:405|SIZE:251387)
+ http://10.252.3.45/robots.txt (CODE:200|SIZE:24)
+ http://10.252.3.45/server-status (CODE:401|SIZE:316)
+ http://10.252.3.45/storage (CODE:200|SIZE:97)
+ http://10.252.3.45/up (CODE:200|SIZE:1935)

--- Entering directory: http://10.252.3.45/css/ ---
+ http://10.252.3.45/css/cgi-bin/ (CODE:301|SIZE:355)
+> DIRECTORY: http://10.252.3.45/css/forms/

--- Entering directory: http://10.252.3.45/images/ ---
+ http://10.252.3.45/images/cgi-bin/ (CODE:301|SIZE:358)

```

Anexo 11:

```

$ nmap -p 27017 10.252.3.45
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-09 16:52 -0600
Nmap scan report for 10.252.3.45
Host is up (0.077s latency).

PORT      STATE      SERVICE
27017/tcp  filtered  mongod
MAC Address: E4:AA:EA:C5:B3:25 (Liteon Technology)

```